

05.27 정기 OMS

웹 개발 필수 교양

JWT에 대해 알아보자

목차

01 JWT란?

02 JWT의 구조

03 세션과 JWT

04 JWT 사용 예시 (Spring)

JWT란?

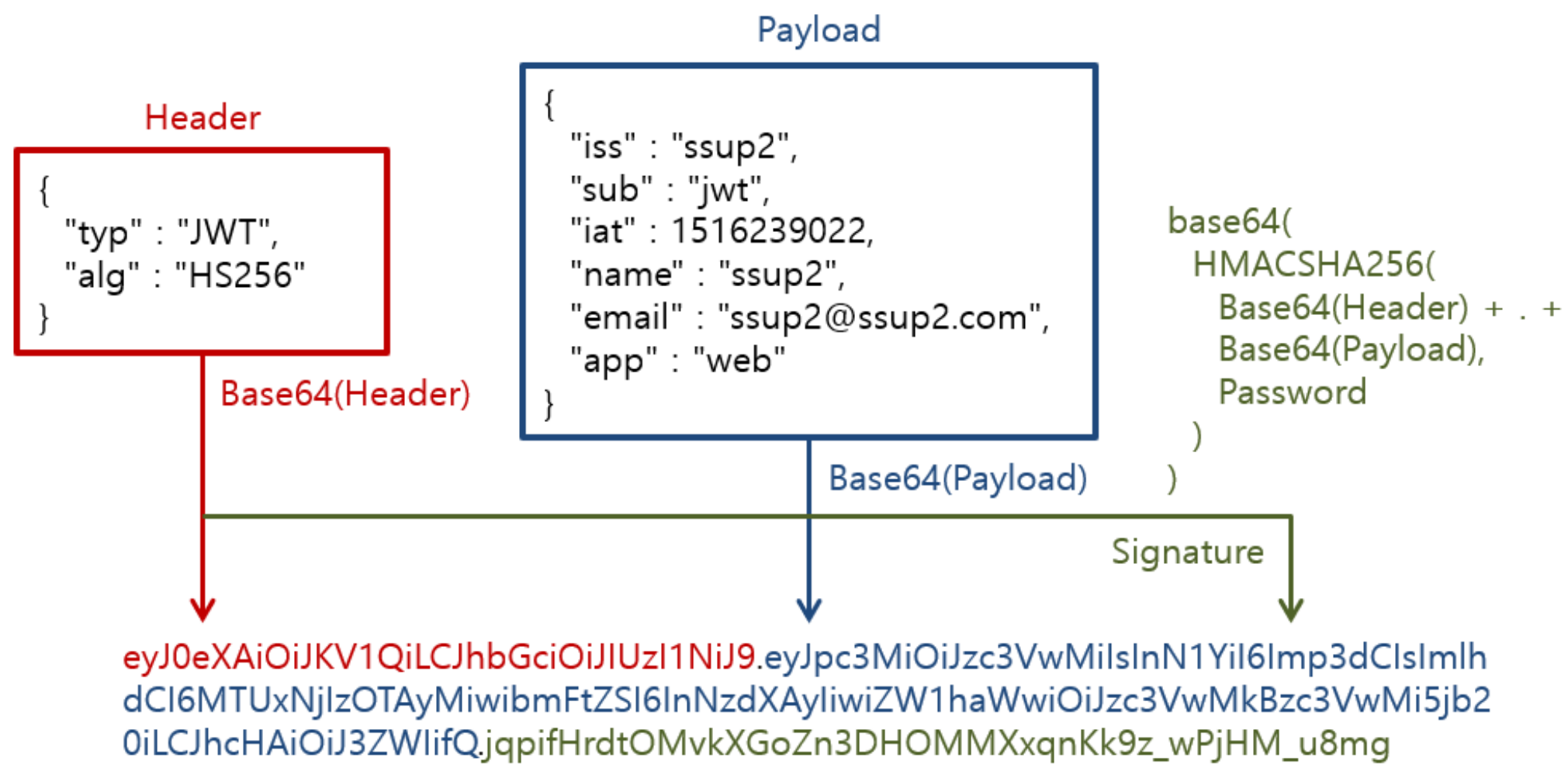
JWT

JSON Web Token

인증 정보를 JSON 형식으로 가지고 있는 문자열이다.

요즘 로그인 구현한다고 하면 이거 밖에 안 쓰는 것 같다.

JWT의 구조



Header

토큰의 유형과 알고리즘 정보가 들어있는 부분

Payload

실제 인증 정보가 들어있는 부분 (최소한의 정보만)

Signature

Header+Payload를 Header에 명시해둔
알고리즘으로 암호화한 부분

Signature 만들기

eyJ0eXAiOiJKV1QiLCJhbGciOiJIUzI1NiJ9.

eyJpc3MiOiJzc3VwMilsInN1Yil6Imp3dCIsImhdCI6MTUxNjZOTAYyMiwiYmFtZSI6InNzdXFyImlyZW1haWwiOiJzc3VwMkIzZVwMi5jb20iLCJhcHAiOiJ3ZWl1fQ

1. Header와 Payload를 base64로 인코딩해서 붙인다.
2. Header에 있는 알고리즘(보통 HS256)을 사용해서 위 문자열을 서버 비밀 키로 암호화한다.

■ 세션과 JWT

세션

로그인을 하면 서버에서 유저를 식별할 수 있는 해시값 하나를 던져줌 (인증 정보 X)

서버는 인증 정보를 세션이라는 데이터로 저장하고 있음

유저는 요청을 날릴 때 그 해시값을 같이 보내면 서버에서는 저장해둔 세션을 조회해서 일치하는 결과가 있으면 인증된 유저로 봄

JWT (토큰)

로그인을 하면 서버에서 인증 정보가 담긴 토큰을 넘겨줌

서버에는 인증 정보가 없고 토큰에 모든 인증 정보가 들어있음

유저는 요청을 날릴 때 토큰을 함께 보내고, 서버에서는 그 토큰이 위조되었는지 검증하고 위조되지 않았으면 인증된 유저로 봄

JWT 사용 예시 (Spring)